

TOSCANA DIAGNOSTICA S.r.l.

Sistema di Gestione Integrato

RELAZIONE SUGLI AMMINISTRATORI DI SISTEMA

Provvedimento Garante per la Protezione dei Dati Personali
del 27 novembre 2008 e successive modifiche
Area 08 – Sistema Informativo

Codice	Revisione	Data	Pagine
TD-SGI-PRO017_00	00	12/04/2026	7
Redatto da	Approvato da	Classificazione	Stato
IT / DPO	AD – Francesco Epifani	Riservato	In vigore

Rif.: TD-SGI-PRO016 (Procedura Sicurezza Sistemi Informativi, Sez. 5, 12, 13)

Responsabile del Documento	RSGI	Emissione del Documento
Francesco Epifani	Iacopo Cupelli	Francesco Epifani
12/04/2026	12/04/2026	12/04/2026

1. Premessa e quadro normativo

Il Provvedimento del Garante per la Protezione dei Dati Personali del 27 novembre 2008, recante “Misure e accorgimenti prescritti ai titolari dei trattamenti effettuati con strumenti elettronici relativamente alle attribuzioni delle funzioni di amministratore di sistema” (pubblicato in G.U. n. 300 del 24/12/2008), e successive modifiche (Provvedimento del 25 giugno 2009), prescrive a tutti i titolari del trattamento una serie di adempimenti specifici in relazione alla figura dell'amministratore di sistema.

Toscana Diagnostica, in qualità di titolare del trattamento di dati personali e di dati sanitari (categorie particolari ex art. 9 GDPR), è tenuta al rispetto integrale del Provvedimento. La presente Relazione documenta le misure adottate e costituisce parte integrante del sistema di gestione della sicurezza delle informazioni (TD-SGI-PRO016) e della documentazione privacy (GDPR / D.Lgs. 196/2003).

2. Riferimenti normativi

Norma / Riferimento	Ambito
Provvedimento Garante 27/11/2008	Misure e accorgimenti per gli amministratori di sistema: designazione, elenco, logging, verifica
Provvedimento Garante 25/06/2009	Modifiche e integrazioni al Provvedimento del 27/11/2008: proroga termini, chiarimenti
Reg. UE 2016/679 (GDPR), artt. 28, 29, 32	Responsabile del trattamento, soggetti autorizzati, misure di sicurezza
D.Lgs. 196/2003, art. 2-quaterdecies	Attribuzione di funzioni e compiti a soggetti designati
ISO 27001:2022, Annex A 5.15, 8.2, 8.5	Controllo accessi, accesso privilegiato, gestione identità
TD-SGI-PRO016	Procedura Sicurezza Sistemi Informativi (Sez. 5: accessi, Sez. 12: formazione AdS, Sez. 13: audit log)

3. Definizione di amministratore di sistema

Ai sensi del Provvedimento del Garante, per “amministratore di sistema” si intende una figura professionale dedicata alla gestione e alla manutenzione di impianti di elaborazione o di loro componenti, incluse le attività di gestione di basi di dati, di reti informatiche, di apparati di sicurezza e di sistemi software complessi. Rientrano nella definizione anche coloro che, pur non svolgendo tale attività come mansione esclusiva, hanno accesso a funzioni privilegiate che consentono di accedere, modificare o cancellare dati personali trattati elettronicamente.

Nel contesto di Toscana Diagnostica, l'architettura cloud-first (TD-SGI-PRO016, Sezione 3) comporta che la maggior parte delle funzioni di amministrazione infrastrutturale (server, database, rete dei datacenter) sia delegata ai fornitori SaaS (Microsoft, DocPlanner, CB Sistemi, ZeeroMED). I soggetti interni di Toscana Diagnostica che rivestono il ruolo di amministratore di sistema sono coloro che dispongono di accessi privilegiati a livello applicativo (console di amministrazione, gestione utenze, configurazione sistemi, accesso ai log) e a livello di rete locale (firewall, switch, Active Directory).

4. Elenco degli amministratori di sistema designati

La seguente tabella riporta l'elenco aggiornato degli amministratori di sistema di Toscana Diagnostica, con indicazione delle funzioni svolte, dell'ambito di operatività e della data di designazione. L'elenco è aggiornato ad ogni variazione e riesaminato annualmente.

Nominativo	Ruolo / Funzione	Sistemi amministrati (ambito)	Designazione	Let. incarico
[Nome Cognome]	Referente IT interno	Microsoft 365 (Entra ID, Exchange, SharePoint): gestione utenze, profili, sicurezza, MFA, Teams admin	[Data]	Sì
[Nome Cognome]	Referente IT interno	GIPOnext: console amministrativa, gestione utenze accettazione e operatori, configurazioni	[Data]	Sì
[Nome Cognome]	Referente IT interno	Rete locale: firewall, switch, VLAN, Wi-Fi, VPN (in coordinamento con WIND)	[Data]	Sì
[Referente CB Sistemi]	AdS esterno (fornitore)	StudioLab LIS: amministrazione database, gestione utenze laboratorio, configurazioni analitiche, backup	[Data]	DPA art. 28
[Referente ZeeroMED]	AdS esterno (fornitore)	ZeeroMED RIS/PACS: amministrazione database DICOM, gestione utenze imaging, archiviazione	[Data]	DPA art. 28
[Referente WIND]	AdS esterno (partner)	Infrastruttura di rete: firewall perimetrale, IPS/IDS, monitoraggio, routing, manutenzione	[Data]	DPA art. 28
[Referente TWY]	AdS esterno (partner)	Centralino VoIP: configurazione, instradamento, IVR, registrazione chiamate	[Data]	DPA art. 28

Per gli amministratori esterni (fornitori SaaS e partner tecnologici), la designazione è formalizzata nel Data Processing Agreement (DPA) ai sensi dell'art. 28 GDPR, che include la clausola specifica relativa agli obblighi dell'amministratore di sistema. Il Titolare verifica annualmente la permanenza delle condizioni di idoneità e l'effettività delle misure di sicurezza adottate dal fornitore.

5. Requisiti di idoneità e criteri di designazione

La designazione degli amministratori di sistema, interni ed esterni, è effettuata dal Titolare del trattamento sulla base di una valutazione delle caratteristiche di esperienza, capacità e affidabilità del soggetto designato, che deve fornire idonea garanzia del pieno rispetto delle vigenti disposizioni in materia di trattamento, ivi compreso il profilo relativo alla sicurezza (Provvedimento Garante, punto 3.1). I criteri di valutazione comprendono:

- Esperienza professionale documentata nella gestione dei sistemi informativi e nella sicurezza delle informazioni.
- Conoscenza della normativa in materia di protezione dei dati personali (GDPR, D.Lgs. 196/2003, Provvedimento sugli AdS).
- Assenza di precedenti disciplinari o penali incompatibili con la funzione.
- Formazione specifica e aggiornamento annuale (TD-SGI-PRO016, Sezione 12: formazione per gli amministratori di sistema, 4 ore annuali).
- Per gli amministratori esterni: certificazioni di sicurezza del fornitore (ISO 27001, SOC 2), clausole DPA conformi al GDPR, garanzie contrattuali sulla riservatezza e sulla protezione dei dati.

6. Ambito e limiti degli accessi privilegiati

Ciascun amministratore di sistema opera esclusivamente nell'ambito dei sistemi e delle funzioni per cui è stato designato. L'accesso privilegiato è disciplinato come segue:

Sistema	Accessi privilegiati concessi	Limiti e restrizioni
Microsoft 365 (Entra ID)	Global Admin o ruoli delegati: gestione utenze, MFA, sicurezza, policy di accesso condizionale, Exchange admin	Non include accesso al contenuto delle caselle e-mail degli utenti; accesso al contenuto solo su autorizzazione scritta del DPO per indagini specifiche
GIPOnext	Admin console: creazione/modifica utenze, configurazione moduli, accesso log, gestione listini e convenzioni	Non include accesso diretto ai dati clinici dei pazienti a livello database; accesso ai dati solo tramite interfaccia applicativa con profilo admin
StudioLab LIS	Admin database e applicativo: gestione utenze laboratorio, configurazione analiti, parametri strumentali, backup e restore	Accesso regolato dal DPA; il fornitore non accede ai dati se non su richiesta documentata del Titolare; attività di manutenzione tracciate
ZeeroMED RIS/PACS	Admin database DICOM: gestione utenze imaging, archiviazione, migrazione, manutenzione	Accesso regolato dal DPA; le immagini DICOM non sono accessibili al fornitore in chiaro senza autorizzazione del Titolare
Rete locale (WIND)	Firewall, routing, VLAN, IPS/IDS, monitoraggio	Nessun accesso ai dati applicativi; accesso limitato alla configurazione di rete e alla gestione del traffico
Fonia VoIP (TWY)	Centralino, instradamento, registrazione chiamate	Nessun accesso al contenuto delle conversazioni; gestione limitata alla configurazione tecnica

7. Registrazione degli accessi (access logging)

In conformità al punto 3.3 del Provvedimento del Garante, Toscana Diagnostica registra gli accessi logici (autenticazione) degli amministratori di sistema ai sistemi di elaborazione e agli archivi elettronici. I log di accesso comprendono:

- Identificativo dell'utente (username o ID univoco dell'amministratore).
- Data e ora dell'accesso (timestamp).
- Tipologia di evento: login, logout, tentativo di accesso fallito.
- Descrizione dell'evento, ove disponibile (sistema operativo, applicativo, indirizzo IP di origine).

Le caratteristiche tecniche del sistema di logging sono le seguenti:

Caratteristica	Implementazione in TD
Completezza	Tutti i sistemi su cui operano gli AdS generano log di accesso: Microsoft 365 (Azure AD Sign-in logs), GIPOnext (log applicativo), StudioLab (log applicativo e database), ZeeroMED (log applicativo e DICOM audit trail), firewall (syslog)
Inalterabilità	I log sono archiviati in modalità append-only su sistemi separati dal sistema amministrato. Per Microsoft 365: Azure Monitor con retention policy immutabile. Per i sistemi dei fornitori: garanzia contrattuale (DPA) di inalterabilità dei log. Per il firewall: syslog su server separato con accesso in sola lettura
Integrità	I log sono protetti da hash crittografico o da meccanismi equivalenti che consentono di rilevare eventuali manomissioni
Periodo di conservazione	Almeno 6 mesi, in conformità al Provvedimento. TD adotta un periodo di conservazione di 12 mesi per i log degli AdS
Accesso ai log	L'accesso ai log degli AdS è riservato al DPO e al soggetto incaricato della verifica annuale. Gli AdS non hanno accesso ai propri log di accesso su sistemi diversi da quello che amministrano

8. Verifica annuale delle attività degli amministratori di sistema

In conformità al punto 3.4 del Provvedimento del Garante, il Titolare del trattamento verifica con cadenza almeno annuale l'operato degli amministratori di sistema, al fine di controllare la rispondenza alle misure organizzative, tecniche e di sicurezza previste dalla normativa. La verifica è condotta dal DPO, in collaborazione con l'RSGI, e comprende i seguenti controlli:

8.1 Verifica dell'elenco degli amministratori

- Controllo della corrispondenza tra l'elenco degli AdS e i soggetti effettivamente in possesso di credenziali privilegiate sui sistemi.
- Verifica che non vi siano utenze privilegiate attive non associate a un AdS designato.
- Verifica che gli AdS cessati o trasferiti abbiano avuto le utenze privilegiate tempestivamente revocate (cross-ref TD-SGI-PRO016, Sezione 5.2).

8.2 Verifica dei log di accesso

- Campionamento e analisi dei log di accesso degli AdS su un periodo di almeno 30 giorni per ciascun sistema.
- Verifica dell'assenza di accessi anomali: accessi in orari inusuali, da indirizzi IP sconosciuti, tentativi di accesso falliti ripetuti, accessi a sistemi non di competenza.
- Verifica della continuità e della completezza dei log: assenza di interruzioni nel periodo di conservazione, integrità dei dati.

8.3 Verifica delle misure di sicurezza

- Controllo che le credenziali degli AdS rispettino i requisiti di complessità e di scadenza (TD-SGI-PRO016, Sezione 5.1).
- Verifica dell'attivazione della MFA sulle utenze privilegiate.
- Controllo che le sessioni remote degli AdS avvengano tramite VPN con autenticazione forte.
- Verifica della formazione specifica degli AdS: partecipazione alla sessione annuale di 4 ore (TD-SGI-PRO016, Sezione 12).

8.4 Verifica dei fornitori esterni

- Controllo della validità del DPA per ciascun fornitore che svolge funzioni di AdS.
- Verifica delle certificazioni di sicurezza del fornitore (ISO 27001, SOC 2).
- Richiesta di reportistica annuale sugli accessi privilegiati effettuati dal personale del fornitore sui sistemi di TD.
- Verifica che gli accessi del fornitore siano avvenuti nei limiti del DPA e delle istruzioni del Titolare.

9. Esiti della verifica annuale

La presente sezione è compilata annualmente dal DPO al termine della verifica e costituisce la documentazione probatoria della conformità al Provvedimento del Garante.

Elemento verificato	Esito	Note / Azioni
Corrispondenza elenco AdS – utenze privilegiate attive	Da compilare alla prima verifica	
Utenze privilegiate non associate a un AdS designato	Da compilare alla prima verifica	
Revoca tempestiva utenze AdS cessati/trasferiti	Da compilare alla prima verifica	
Completezza e continuità dei log di accesso (6+ mesi)	Da compilare alla prima verifica	
Assenza di accessi anomali nei log campionati	Da compilare alla prima verifica	
Inalterabilità e integrità dei log	Da compilare alla prima verifica	
Credenziali AdS conformi (complessità, scadenza, MFA)	Da compilare alla prima verifica	
VPN con autenticazione forte per accessi remoti	Da compilare alla prima verifica	
Formazione annuale AdS completata (4 ore)	Da compilare alla prima verifica	
DPA fornitori esterni validi e aggiornati	Da compilare alla prima verifica	
Certificazioni fornitori verificate (ISO 27001, SOC 2)	Da compilare alla prima verifica	
Reportistica accessi fornitori ricevuta e verificata	Da compilare alla prima verifica	

Esito complessivo della verifica annuale: _____

Data della verifica: ____/____/____

DPO – Verifica	RSOI – Collaborazione	AD – Presa visione
Firma: _____	Firma: _____	Firma: _____
_____	_____	_____
Data: ____/____/____	Data: ____/____/____	Data: ____/____/____

10. Obblighi di informativa e comunicazione

In conformità al punto 3.2 del Provvedimento del Garante, l'elenco aggiornato degli amministratori di sistema, con l'indicazione delle funzioni attribuite, è reso disponibile al DPO, al Titolare del trattamento e, in caso di richiesta, al Garante per la Protezione dei Dati Personali. L'elenco è aggiornato ad ogni variazione (nuova designazione, cessazione, modifica di ambito) e comunque riesaminato annualmente in occasione della verifica. Le variazioni sono comunicate all'AD entro 5 giorni lavorativi.

Qualora i servizi di amministrazione di sistema siano affidati a soggetti esterni (come nel caso dei fornitori SaaS di TD), il Titolare conserva direttamente e specificamente, per ogni eventuale evenienza, gli estremi identificativi delle persone fisiche preposte quali amministratori di sistema presso il fornitore, ove contrattualmente possibile, ovvero acquisisce dal fornitore la garanzia di idoneità e la documentazione delle misure adottate.

11. Aggiornamento della relazione

La presente Relazione è aggiornata: in occasione della verifica annuale (compilazione della Sezione 9); ad ogni variazione dell'elenco degli amministratori di sistema (Sezione 4); a seguito di modifiche significative dell'architettura dei sistemi informativi (nuovi sistemi, dismissioni, cambi di fornitore); a seguito di eventuali provvedimenti o indicazioni del Garante. L'RSOI cura l'aggiornamento e l'archiviazione della Relazione nel sistema documentale del SGI.

12. Storico delle revisioni

Rev.	Data	Descrizione modifiche	Approvazione
00	12/04/2026	Prima emissione	Francesco Epifani